

Informe de cumplimiento normativo

Sterclicks — Comercio electrónico de figuras personalizadas

Jerez de la Frontera, Cádiz, España

Agosto de 2026

Este informe resume el estado y las medidas adoptadas o en curso por Sterclicks en materia de protección de datos (RGPD y LOPDGDD), comercio electrónico (LSSI-CE), protección de consumidores (TRLGDCU) y seguridad de la información. Se indica expresamente qué medidas están ya implementadas y cuáles se encuentran en fase de implementación, con el objetivo de documentar de forma transparente el nivel de cumplimiento normativo del negocio ante terceros.

1. Identificación del responsable del tratamiento

Sterclicks opera como tienda online de venta de figuras personalizadas estilo Playmobil, con sede en Jerez de la Frontera (Cádiz, España). La plataforma está construida sobre CodeIgniter 4 y alojada en infraestructura de Hostinger.

2. Aviso legal y condiciones de contratación

En cumplimiento del artículo 10 de la Ley de Servicios de la Sociedad de la Información y Comercio Electrónico (LSSI-CE), el sitio web debe incorporar un Aviso Legal con la identificación completa del titular de la actividad, datos de contacto y, en su caso, datos de inscripción registral. Sterclicks se encuentra en proceso de revisión y actualización de los siguientes documentos legales:

- **Política de Privacidad**, a actualizar para reflejar todas las finalidades del tratamiento (gestión de cuenta, pedidos, envíos, y comunicaciones comerciales bajo consentimiento explícito).
- **Condiciones Generales de Contratación**, con precio, gastos de envío, plazos de entrega y formas de pago, a mostrar antes de formalizar la compra.
- **Política de Cookies** con banner de consentimiento previo a la instalación de cualquier cookie no estrictamente necesaria — pendiente de implementación técnica.

3. Protección de datos personales (RGPD / LOPDGDD)

3.1 Base legal de los tratamientos

Los datos recogidos en el registro de usuarios se tratan bajo la base legal de "ejecución de contrato" para la prestación del servicio (acceso al panel de usuario y personalización de producto). Para el envío de comunicaciones comerciales se ha implementado un proceso específico de recogida de **consentimiento explícito**, independiente del registro inicial, conforme al artículo 21.2 de la LSSI-CE y al artículo 6 del RGPD.

3.2 Gestión del consentimiento de marketing

Se ha desplegado un sistema de doble verificación (opt-in) mediante el cual cada usuario recibe una comunicación neutra invitándole a confirmar su interés en recibir promociones. Solo los usuarios que confirman expresamente mediante un enlace único y personal quedan habilitados para recibir marketing. Cada confirmación o revocación queda registrada con fecha, hora, dirección IP y agente de usuario, constituyendo evidencia documental del consentimiento otorgado.

3.3 Derechos de los interesados

Sterclicks se compromete a garantizar el ejercicio de los derechos de acceso, rectificación, supresión, limitación, portabilidad y oposición (derechos ARSULIPO). Se encuentra en curso la habilitación de un canal de contacto dedicado para su ejercicio, con compromiso de respuesta en el plazo de un mes establecido por el RGPD.

3.4 Encargados del tratamiento

Los proveedores tecnológicos que procesan datos personales por cuenta de Sterclicks —alojamiento web (Hostinger), envío de comunicaciones (Brevo), almacenamiento de copias de seguridad (Backblaze B2) y, en su caso, gestión logística— han sido seleccionados con centros de datos ubicados en la Unión Europea. La formalización de los contratos de encargado de tratamiento (art. 28 RGPD) con cada uno de ellos se encuentra en curso.

3.5 Registro de Actividades de Tratamiento

Sterclicks se encuentra elaborando su Registro de Actividades de Tratamiento (RAT) conforme al artículo 30 del RGPD, que documentará cada finalidad, categoría de datos, base legal, plazo de conservación y medidas de seguridad aplicadas.

3.6 Protocolo ante brechas de seguridad

Se encuentra en definición un procedimiento interno para la detección, evaluación y, en su caso, notificación de brechas de seguridad a la Agencia Española de Protección de Datos en el plazo de 72 horas exigido por el artículo 33 del RGPD, así como la comunicación a los interesados afectados cuando exista riesgo elevado para sus derechos y libertades.

4. Protección de personas consumidoras

En cumplimiento del Texto Refundido de la Ley General para la Defensa de los Consumidores y Usuarios (TRLGDCU), Sterclicks se compromete a informar de manera clara y previa a la compra sobre las características del producto, precio total con impuestos incluidos, gastos de envío y plazos de entrega estimados. Los siguientes puntos se encuentran en revisión para asegurar su correcta implementación en el proceso de compra:

- Al tratarse de productos confeccionados conforme a especificaciones personalizadas del consumidor (figuras personalizadas), debe informarse expresamente de la exclusión del derecho de desistimiento prevista en el artículo 103.c) del TRLGDCU para este tipo de productos.
- Envío de confirmación de pedido por correo electrónico con el detalle completo de la compra.
- Hace visible a la plataforma europea de resolución de litigios en línea (ODR) para consumidores de la Unión Europea.

5. Medidas de seguridad técnica y organizativa

En aplicación del artículo 32 del RGPD, Sterclicks aplica o está implementando las siguientes medidas de seguridad, proporcionadas al riesgo del tratamiento:

- Cifrado del tráfico web mediante HTTPS en la totalidad del sitio.
- Almacenamiento de contraseñas de usuario mediante algoritmos de hash criptográfico robustos (nunca en texto plano ni con algoritmos obsoletos) — en verificación técnica.
- Revisiones periódicas de seguridad de la aplicación (protección frente a inyección SQL, XSS y CSRF).
- Limitación de intentos de acceso (rate limiting) en los formularios de autenticación — pendiente de implementación.
- Autenticación de doble factor para el acceso al panel de administración — pendiente de implementación.
- Registro (log) de accesos administrativos con fecha e identificación de origen — pendiente de implementación.
- Sistema de copias de seguridad automáticas y cifradas (AES-256) de la base de datos, desarrollado y listo para despliegue, con almacenamiento en infraestructura ubicada en la Unión Europea, política de retención limitada y borrado automático de copias caducadas.

6. Procesamiento de pagos

El procesamiento de pagos con tarjeta se realiza a través de pasarelas de pago externas certificadas bajo el estándar PCI-DSS. Se está verificando que la integración actual no almacene, procese ni transmita a través de sistemas propios datos de tarjetas de pago en ningún momento del proceso de compra.

7. Accesibilidad digital

Sterclicks está evaluando la aplicabilidad de los requisitos de accesibilidad establecidos por la normativa de transposición de la Directiva (UE) 2019/882 sobre requisitos de accesibilidad de productos y servicios, en función de su volumen de actividad y tamaño de empresa, y las posibles exenciones aplicables a microempresas.

8. Resumen ejecutivo

Área	Estado
Aviso Legal y Condiciones Generales	En revisión
Política de Cookies y banner de consentimiento	Pendiente
Consentimiento explícito para marketing (sistema de opt-in)	Implementado
Derechos ARSULIPO / canal de contacto	En curso
Registro de Actividades de Tratamiento (RAT)	En elaboración
Contratos de encargo de tratamiento (DPA)	En curso
Protocolo de notificación de brechas	En definición
Información precontractual y derecho de desistimiento	En revisión
Copias de seguridad cifradas en la UE	Desarrollado, pendiente despliegue
Autenticación de doble factor (panel admin)	Pendiente
Procesamiento de pagos externalizado (PCI-DSS)	En verificación
Accesibilidad digital	En evaluación

Documento elaborado con carácter informativo para acreditar el grado de cumplimiento normativo de Sterclicks ante terceros. No constituye asesoramiento jurídico ni sustituye la revisión de un abogado especializado en protección de datos o de un Delegado de Protección de Datos (DPO).